ACC-11 · Vendor, Contractor & Consultant Account Standard

The account class for people who work with the organization but not for it — the sponsor, the expiry that is not negotiable, and the day the relationship quietly changes.

Field	Value
Document ID	ACC-11
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 3 — Expert Services holds vendor identities and all vendor privileged access. Tier 4 approves standing privileged access and every exception. Tier 2 creates and ends the routine contractor account.
Review cycle	Annually. The vendor access register is reviewed quarterly, not annually — §9.
Relationship to ACC-10	ACC-10 decides whether an outsider needs an identity at all, and creates a guest where collaboration is the whole of it. This document is the next rung up: the outsider who must act inside organization systems rather than collaborate on documents. ACC-10 §2 hands cases here.

1. Purpose — two cases, one gap

Two common situations, often years apart, are the same problem seen from two ends.

A departing senior staff member explains that their organization records are in a personal OneDrive because they originally joined as a consultant. The arrangement made at the beginning was correct for a consultant. It was never revisited when they became, in every practical sense, a member of staff — and the cost lands years later, under time pressure, as a rescue project: standing up a handover SharePoint site and re-permissioning content in the middle of somebody's departure.

A vendor engineer applies vulnerability remediation to the test and then production servers of the organization's core business system inside the maintenance window. That is an outside party holding standing privileged access to a system of record, coordinated by an email thread. Nothing goes wrong. But often almost nothing about the arrangement is written down: not the named individuals who hold the access, not what they can reach when they are not patching, not what the organization requires of them, and not what happens to any of it when the contract ends.

One case is an account class that never changed when the relationship did. The other is an account class that was never defined at all. This document defines it, and gives both cases a trigger.

2. Which account class

Decided at the point of request, before anything is created. Creating the wrong class quickly is worse than taking a day to create the right one, because the wrong class is what nobody revisits.

They are...	Class	What they get	Governed by
Someone who needs a document, a briefing or a file. No access to anything.	No account	The document, or a link with an expiry.	M365-14 §6
At another organisation, collaborating with us on specific work for a bounded period. The default for most external relationships.	Guest (B2B)	Sign-in with their own organisation's credentials. No mailbox of ours, no licence.	ACC-10 + M365-14
A supplier with operational access to our systems — an implementation partner on the HR system, a managed security provider in the security tooling, an application vendor doing support.	Sponsored vendor account	A named identity of ours per individual, expiring at the contract date, with access scoped to the contracted work.	THIS DOCUMENT, plus ACC-07 where the access is privileged
A contractor or consultant engaged directly by the organization, working alongside staff on organization work, for a defined engagement.	Sponsored contractor account	A named identity of ours with an engagement-end expiry, entitlements matched to the work and re-baselined at any extension.	THIS DOCUMENT
Doing the work of an organization employee on an ongoing basis, whatever the contractual label — the long-term consultant, the seconded colleague, the interim postholder.	Full staff account	A normal identity with an HR record behind it.	ACC-01 §5. HR creates the record first; §5 of this document is the transition.

The distinction between the third and fourth rows is who engaged them and on whose systems the work is done; the distinction between the fourth and fifth is whether the relationship is bounded. The fifth row is the one people get wrong, and §5 is about that.

3. The sponsor

Every vendor and contractor identity has one named staff member accountable for it — normally the person who owns the working relationship, not Procurement and not IT. IT operates these accounts; it does not vouch for the people holding them.

The sponsor	
Requests it	Raises the request with the individual's name, the organisation, the contracted purpose in one sentence, what they need to reach, and the contract or engagement end date.
Vouches for the individual	Is stating, on the record, that this named person should be able to act inside organization systems. For a vendor, that means the individual and not merely the firm.

The sponsor	
Owns the scope	Answers the question “why does this account need that?” at the quarterly review. A sponsor who cannot is the signal that the scope was never examined.
Reports change	Tells IT when the individual leaves the vendor, when the engagement is extended, and when the relationship changes character (§5). The contract does not tell IT any of this; the sponsor does.
Ends it	Tells IT at contract end without waiting for the expiry to do it. The expiry is the safety net, not the process.
Is replaced when they leave	A vendor account whose sponsor has left is reassigned during the leaver procedure or expired (ACC-01 §7.2). An unsponsored vendor account with privileged access to the ERP is not a housekeeping matter.

4. The expiry date is the contract date

> **Set at creation. Not negotiable.**
>
> Every vendor, contractor and consultant account carries an expiry date equal to the contract or engagement end date, entered when the account is created and before the credentials are handed over. Not “we will sort it out later”. Not “ongoing”. Not blank.
>
> Where the agreement genuinely has no end date — a rolling support contract, an evergreen licence with support attached — the account carries a 12-MONTH expiry renewable on the sponsor’s confirmation. An account whose end date is “whenever the relationship ends” has no end date at all, and relationships routinely end without anybody telling IT.
>
> The negotiation people expect to have is about whether the expiry can be waived. It cannot, and IT should not be drawn into having that conversation case by case. What is negotiable is the RENEWAL, which takes one email from the sponsor and is granted routinely wherever the work is continuing.

- Fourteen days before expiry, the sponsor is asked one question: does the engagement still run, and does the access still match it?
- No response means expiry. Renewal is the action; expiry is the default. This single rule is the difference between a vendor register and a vendor accumulation.
- A renewal is not a rubber stamp on the previous scope. It re-confirms the entitlements as well as the dates — an extension is the natural moment to notice that access granted for a migration years ago is still in place.
- Where an extension is agreed after the account has expired, the account is re-enabled rather than recreated, and the gap is recorded. A gap of a few days is unremarkable; a gap of four months is a fact worth having on the record.
- The expiry applies to the identity, to any VPN or remote access profile (DEV-10), and to any non-human account created for that vendor’s integration (ACC-08 §11).

5. When the relationship changes — conversion in both directions

This is the section the consultant case in §1 wrote. A relationship that changes character without the account class changing with it produces an identity that is correct for a job the person no longer has, and nobody notices for years because everything works.

5.1 Consultant becomes staff

The person is now doing the work of an employee. HR creates the record; a staff identity is created under ACC-01 §5; and the consultant account is closed rather than relabelled.

- The triggers that should prompt a class review, any one of them: the person attends standing departmental meetings; they hold or produce institutional records; they supervise or direct staff; colleagues use their organization address as the primary route to them; they appear in an organisation chart; or the engagement has been extended more than twice.
- The sponsor raises the class review. IT may also raise it — a technician who notices that a "consultant" has held an account for three years is doing the organization a service, and should be thanked rather than told it is not their business.
- Content held in the consultant's OneDrive is moved to the departmental SharePoint site as part of the transition, not at some later departure. This is the exact cost the §1 consultant case pays, and the transition is the cheap moment to pay it (M365-12, M365-16 §5).

5.2 Staff becomes consultant

The harder direction, because the access already exists and the path of least resistance is to leave it alone. A retiring colleague retained for a project, or a departing administrator staying on for a handover, does not simply keep what they had.

1. The full leaver procedure runs (ACC-01 §7.2). Sessions revoked, entitlements removed, disposition set under ACC-12. This happens even though the person is coming back on Monday.
2. A new account is created under this document, with a sponsor and a contract-end expiry.
3. Entitlements are granted from zero against the contracted work — not carried over, and not restored from a list of what they used to have.
4. Any privileged access is re-approved by Tier 4 as a new grant (ACC-07). Previous seniority is not an entitlement.
5. The class change is recorded (Appendix B), including what was removed. The record is what makes the following year's review meaningful.

A class change is a re-baseline, never a continuation.

If entitlements are carried across a class change, the person accumulates the union of every role they have ever held — which is how a former Finance administrator ends up as a consultant with standing access to payroll-sensitive material that nobody granted deliberately.

This will occasionally feel discourteous, and it is worth saying so to the person rather than letting them discover it. The framing that works is honest: the organization is not withdrawing trust, it is matching access to the current engagement, and anything genuinely needed is granted the same week on the sponsor's request.

The alternative framing — quietly leaving the old access in place because it would be awkward to remove — is the one that has to be defended later, and it cannot be.

6. Vendor access to servers: standing, scheduled or just-in-time

The vendor case in §1 is the model: a vendor holding access to a core system's test and production servers, applying remediation in the maintenance window, coordinated by email. The question this section answers is not whether that access should exist — it must — but what shape it should hold between windows.

Model	How it works	Assessment
Standing privileged access	The vendor's named accounts hold their privileges permanently and use them when needed.	The usual shape for at least part of most estates. Simple, always available, and a permanent high-value credential outside the organization's direct control. Acceptable only with §7 in force and quarterly review.
Scheduled window access	Privileges are enabled for an agreed maintenance window and disabled afterwards, under a change record.	A significant improvement for planned work such as patching, and it matches how planned vendor remediation usually runs. The window is already agreed; this only adds the enable and disable.
Just-in-time elevation	The account exists but holds no standing privilege. Elevation is requested, approved and time-bound, and it expires automatically.	RECOMMENDED DIRECTION. The credential is worth much less when it is not elevated, which is most of the time. Requires tooling and a workflow that many organizations do not yet have everywhere.
Escorted session	The vendor works in a session one of our engineers is present in and can end.	Right for high-risk or unfamiliar work; too expensive for routine support in a department that is already stretched. Reserve it rather than aspire to it.

The recommendation, and an honest word about pace

The organization should move toward time-bound elevation and away from standing vendor privilege. That is the direction, and this document states it plainly so that each new agreement is written against it rather than against the status quo.

It should equally be said that this is a direction, not a switch. A core vendor's access is usually operationally necessary, small IT teams are stretched, and no document turns standing access off on a Tuesday.

The interim steps cost very little and can start now: named individual accounts rather than shared logins (§7); the standing set enumerated and reported to Tier 4 (§9); privileged vendor sessions logged; and every maintenance action carrying a change record under GOV-04 instead of living in an email thread. The last of those is the one that turns the §1 vendor case from a habit into a record.

7. Vendor privileged access requirements

- NAMED INDIVIDUAL ACCOUNTS. Never a shared vendor login. When a vendor rotates its engineers — and they do — a shared credential is held by an unknown and changing set of people, none of whom the organization has ever heard of, and no log will ever say which of them did what.
- Multifactor authentication on every vendor identity, with no exemption. A vendor account is a remote credential by definition, and remote credentials are the ones that get used from somewhere else.
- Session logging on privileged vendor activity, retained per §12. The purpose is not suspicion; it is that when something changes on a system of record, the organization can say what changed and who changed it.
- A change record under GOV-04 for every action that alters a production system, including vendor-initiated patching. The maintenance window is agreed; the record is what makes it reconstructable afterwards.
- No vendor account holds standing Global Administrator or Domain Admin (ACC-07 §5). Where a vendor requires it as a condition of support, that requirement goes into the contract conversation, not into the directory.
- Access from the vendor's managed device where the contract provides for it, and from a defined source where it does not. "From anywhere" is a choice, and it should be a recorded one.
- Vendor privileged accounts are reviewed QUARTERLY, not annually (§9). They are a small population with a large blast radius, which is exactly the case where frequent review is affordable.
- Any non-human account created for a vendor integration is registered and governed under ACC-08, and its owner is one of our staff — never the vendor.

8. What the organization requires before access is granted

IT does not write contracts, and this list is not contract language. It is what IT needs the agreement to contain, expressed so that Procurement can take it to counsel without a translation step. Where an agreement is already signed without these, the gap is recorded rather than pretended away, and it is raised at renewal.

Requirement	Why	Owned by
Named individuals, with contact details, and notification of any change within five business days	The organization cannot review, log or offboard a set of people it cannot name. This is the clause that makes §7 possible.	Procurement, from IT's list
Access used only for the contracted purpose	Turns the scope from an assumption into a term. It is also what makes an out-of-scope action a contract matter rather than an argument.	Procurement
Multifactor authentication, and no credential sharing within the vendor	The vendor's internal convenience must not become the organization's shared credential.	Procurement + IT
Security incident notification to the organization within 24 hours	A breach at a vendor holding privileged access to a system of record is an organization incident (GOV-03). The organization should not learn of it from the news.	Procurement
Screening appropriate to the access held	A vendor engineer with administrative access to the system of record holds more than most employees do.	HR + Procurement
Confidentiality and data handling, referencing the sensitive classes in M365-15	Vendor staff will encounter customer, staff and payroll data in the course of ordinary support. The handling expectation has to be written before that happens, not after.	Procurement
Right to receive access and session logs, and to audit	Without it the organization can be told what happened but cannot verify it.	Procurement
Return or destruction of organization data at contract end, confirmed in writing	Ending the account does not end the copy of the data on the vendor's laptop or in their ticketing system (§10).	Procurement
Subcontractor disclosure	Access granted to a firm is frequently exercised by another firm. The organization should know that before it happens.	Procurement

Where a contract cannot be changed before access is genuinely needed, access may be granted on a Tier 4 exception with a 90-day expiry and the gap recorded on the risk register. That is a deliberate, bounded decision by somebody with the authority to make it — not a technician deciding under pressure at 4pm.

9. The quarterly vendor access review

Run under ACC-17, produced by Tier 3, taken to Tier 4 and copied to each sponsor. One page per vendor.

- WHAT IT LISTS: the vendor, the named individuals, the account class, the sponsor, the contract end date, the expiry set on each account, the entitlements held, whether any privilege is standing, the last sign-in, and any change since the previous quarter.
- THE QUESTIONS: does the engagement still run; are these still the right individuals; is the access still matched to the work; can any standing privilege become scheduled or just-in-time (§6); and has the sponsor changed?

- A vendor account with no sign-in for a quarter is not proof that it is unneeded — some support relationships are genuinely dormant between incidents. A vendor account signing in daily is not proof that it needs the level it holds. Both are questions for the sponsor, and the review is where they get asked rather than assumed.
- An account whose sponsor does not respond to two consecutive reviews is escalated to Tier 4 and disabled. The presumption sits with removal, because the alternative presumption is how vendor access becomes permanent.
- The review's output includes a count: how many external individuals can act inside organization systems today. That single number is the one the Head of IT will be asked for, and it should not require a week's work to produce.

---

10. Offboarding at contract end

1. The sponsor notifies IT at contract or engagement end. Where they do not, the expiry set under §4 catches it — which is the entire purpose of §4.
2. Disable the accounts; do not delete them. Deleting destroys the record of what the vendor held, which is exactly what is wanted six months later.
3. Revoke sessions and tokens, and remove VPN and remote access profiles (DEV-10).
4. ROTATE EVERY CREDENTIAL THE VENDOR HELD OR COULD RETRIEVE — shared appliance and console passwords, any service account they were given, any certificate or secret they installed (ACC-08 §6, §10). This is not a comment on the vendor. It is what makes it possible to state, afterwards, that the credential is no longer outside the organization.
5. Remove them from privileged groups and record what was removed before removing it.
6. Confirm in writing that organization data held in the vendor's own systems has been returned or destroyed, per §8. The account ending does not reach their laptop, their ticketing system or their backups, and this is the only mechanism that does.
7. Close the register entry with the date, and note any non-human account created for the integration so it goes through ACC-08 §11 rather than being left running.
8. Where the vendor relationship ended badly, treat it as an immediate separation: same-hour disable, credential rotation first, and Tier 4 informed (GOV-03 if there is any suspicion of misuse).

> **Contract end is rarely a clean event, and the procedure should assume it is not**
>
> A support agreement lapses and is renewed six weeks later. A project "finishes" but the vendor is still answering questions months later. An engineer leaves the vendor and nobody thinks to say so.
>
> The expiry date handles all three correctly: the account expires, and a renewal takes one email from the sponsor. The failure mode this prevents is the account staying live across a gap that nobody is tracking — which is not a theoretical risk, it is what happens by default.

11. Service levels

Activity	Commitment (per GOV-06)
Vendor or contractor account, complete request with sponsor and end date	P3 — within 3 coverage days.
Request missing the end date or the sponsor	Returned same day with what is missing. Not held silently, and not created on a best guess.
Privileged vendor access request	Tier 4 decision. Within 5 coverage days, or the next Tier 4 sitting.
Scheduled window elevation for agreed maintenance	Enabled and disabled with the change record (GOV-04).
Renewal on sponsor confirmation	Same coverage day.
Offboarding at contract end	Within 1 coverage day of notification, or automatically at expiry.
Urgent removal on security grounds or a bad ending	P1 — 30 minutes, credential rotation first.
Quarterly vendor access review to Tier 4	On schedule.

12. Records

Record	Held in	Retention
Vendor and contractor register, with class, sponsor, scope, expiry	IT register	Live, plus 3 years after the account ends
Sponsor request and vouching	Ticket	3 years
Class-change records (§5, Appendix B)	IT register + HR where staff status changes	7 years
Tier 4 approvals for privileged vendor access	Tier 4 record	7 years
Privileged vendor session logs	Security logging	Per GOV-03; minimum 1 year
Change records for vendor maintenance actions	Change record (GOV-04)	3 years
Quarterly review outcomes, including the external-individual count	Tier 4 record	3 years
Written confirmation of data return or destruction	Procurement + IT register	Life of contract + 7 years
Exceptions granted where contract terms were absent (§8)	Risk register + Tier 4 record	7 years

13. Related documents

ID	Title	Relationship
ACC-10	Guest & Sponsored External Account Standard	The rung below. ACC-10 §2 routes cases here.

ID	Title	Relationship
ACC-07	Privileged & Administrative Account Standard	§7 — vendor privileged access is privileged access held outside the organization.
ACC-08	Service, Application & Non-Human Account Standard	Vendor integrations carry non-human identities; §10 offboarding covers them.
ACC-01	Account Lifecycle	§5.2 — the leaver procedure runs even when the person is coming back on contract.
ACC-12	Separation, Retiree & Former-Member Disposition	The disposition applied when staff status ends, before a contractor account begins.
ACC-16	Application Onboarding, SSO & SAML Claims Standard	Where a vendor brings an application with them.
ACC-17	Periodic Access Review & Entitlement Recertification	The quarterly review in §9.
ACC-02	Account Naming Standard	Vendor identities are visibly external at a glance.
DEV-13	Patch, Update & Maintenance Window Standard	The vendor patching activity this document gives an identity to.
DEV-14	Endpoint Security Agent & MDR Escalation Standard	A managed security provider's access to the security tooling is vendor access under this document.
DEV-10	Remote Access & VPN Standard	How vendors reach the estate, and what is revoked at §10.
GOV-04	IT Change Management & Maintenance Windows	§6 and §7 — the change record that replaces the email thread.
GOV-03	Security Incident Response	Vendor-side incidents, and bad endings.
M365-12	OneDrive Institutional Data Boundary	§5.1 — the consultant case, and where the records should have been.
M365-15	Data Classification & Handling	§8 handling terms.

Appendix A — Vendor & contractor access request

Raised by the sponsor. An incomplete request is returned rather than actioned on a best guess — particularly the end date, which is the field people leave blank.

Field	Entry
Individual's full name	One request per individual. Not "the vendor's team".
Organisation	
Class requested (§2)	Guest / vendor / contractor / staff conversion
Sponsor	A named staff member of ours, with their role

Field	Entry
Contracted purpose	One sentence
Systems and data they need to reach	Named. Not “the usual access”.
Is any of it privileged?	YES requires Tier 4 approval and §7 in full
Standing, scheduled or just-in-time (§6)	And the reason, if standing
CONTRACT / ENGAGEMENT END DATE	MANDATORY. If there is no end date, enter “rolling — 12-month expiry” (§4).
Contract reference, and does it contain §8?	YES / NO / partially — NO requires a Tier 4 exception with a 90-day expiry
Remote access required?	DEV-10 profile, and from where
— IT USE — Class confirmed, expiry set	Date, by whom
— IT USE — Tier 4 approval where privileged	Name, date
— IT USE — Register entry created	Reference

Appendix B — Class-change record

Used in both directions: consultant becoming staff, and staff becoming consultant. The point of the record is that the change was deliberate, dated and re-baselined — not a continuation nobody decided on.

Field	Entry
Person	
Change	Consultant → staff / staff → consultant / guest → contractor / other
What triggered it (§5.1)	Named trigger, or the sponsor’s statement
HR record created or ended	Reference, and HR contact
Entitlements held BEFORE the change	Full list, attached. Captured before anything is removed.
Entitlements removed	Full list
Entitlements granted against the NEW role, from zero	Full list
Privileged access re-approved by Tier 4?	YES / NO / not applicable
OneDrive content: institutional records moved to the departmental site?	YES — site named / not applicable. This is the step most often missed.
New expiry date, where the new class carries one	
Sponsor for the new class	
Recorded by, date	

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.